Análise de arquivo malware

Share

codigo.c
179 lines

C

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Verificando o que o módulo faz e como responder sem detalhar o código

Veredito: não é benigno. O arquivo é um keylogger em nível de kernel e deve ser tratado como malware.

Funcionalmente, é um módulo do kernel Linux que captura as teclas digitadas no sistema inteiro, incluindo senhas e mensagens privadas. Ele guarda esse conteúdo e o deixa disponível para leitura posterior por um dispositivo do sistema, sem aviso nem consentimento do usuário. O nome do autor e do dispositivo indicam que provavelmente é uma prova de conceito pública, talvez com intenção educacional. Isso não muda o comportamento: se ele aparecer num sistema onde você não o instalou de propósito, é spyware.

Quanto ao passo a passo, aqui no claude.ai eu não faço detalhamento técnico nem explico o funcionamento de código malicioso, mesmo para fins legítimos como estudo ou análise de ameaças. Imagino que seu objetivo seja defensivo. Se essa restrição não fizer sentido para o seu caso, o botão de polegar para baixo permite enviar feedback à Anthropic.

Posso ajudar bastante pelo lado da defesa. Não compile nem carregue esse arquivo em um sistema real. Se você o encontrou numa máquina e suspeita de comprometimento, lembre que carregar um módulo de kernel exige privilégios de root, então a presença dele já sugere acesso privilegiado prévio. Vale conferir `lsmod`, `/proc/devices` e o `dmesg` procurando nomes como “maK_it” ou “maKit”. Depois, isole a máquina da rede, troque as senhas a partir de outro dispositivo confiável e, idealmente, preserve disco e memória para perícia antes de reinstalar o sistema. Como prevenção, ajudam:

- Secure Boot com exigência de assinatura de módulos
- o modo lockdown do kernel
- `kernel.modules_disabled=1` após o boot
- regras do auditd para as chamadas `init_module` e `finit_module`
- ferramentas como rkhunter e chkrootkit, que ajudam mas não detectam tudo

Essa conclusão vem só da leitura do código-fonte. Não compilei nem executei nada, e o arquivo sozinho não diz se alguma máquina foi realmente afetada. Se quiser, posso ajudar a montar um checklist de resposta a incidentes ou de hardening para o seu ambiente.

Qual é a categoria principal deste malware?

Enquadrando o módulo como keylogger de kernel

A categoria principal é **spyware, na forma de um keylogger (registrador de teclas) em modo kernel.**

Ele chega ao sistema como um módulo carregável do kernel Linux (LKM). Por rodar no nível do kernel, muita gente o chama de "rootkit", mas o traço definitivo de um rootkit é esconder a própria presença (processos, arquivos, o próprio módulo), e pelo que o código mostra, esta amostra não faz isso. Também não se encaixa como ransomware, worm, backdoor ou stealer completo: o arquivo não tem propagação nem envio de dados pela rede. Ele só coleta as teclas e as deixa disponíveis localmente, então um atacante precisaria de outro componente para retirá-las da máquina.

Para quem trabalha com detecção, o equivalente no MITRE ATT&CK é a técnica **T1056.001 (Input Capture: Keylogging)**. Como esta amostra não se oculta, ela tende a aparecer em `lsmod`, como mencionei antes. Se quiser, posso ajudar a transformar isso em regras de detecção para o seu ambiente, como as do auditd.